NEXTREPORTING

INFORMATION SECURITY POLICY

Version 1.0

1. PURPOSE

The purpose of this Information Security Policy ("**Policy**") is to describe the principles, governance framework and security measures implemented by ATEBIZ ("**Provider**") to protect the confidentiality, integrity, availability and resilience of the NEXTREPORTING Software-as-a-Service platform ("**Service**").

This Policy forms part of the contractual documentation applicable to the Service and shall be read together with the General Subscription Terms and Conditions, the Data Processing Agreement and the Service Level Agreement.

Nothing contained in this Policy shall be interpreted as limiting the Provider's right to improve or strengthen its security programme from time to time.

2. SECURITY GOVERNANCE

The Provider maintains an information security governance framework designed to identify, assess, manage and continuously reduce information security risks affecting the Service.

Information security is embedded throughout the lifecycle of the Service, including system design, software development, deployment, operation, maintenance and decommissioning.

Security controls are periodically reviewed in light of technological developments, evolving cyber threats, operational experience and applicable legal or regulatory requirements.

Where appropriate, the Provider aligns its security practices with internationally recognised information security standards and industry best practices.

3. SECURITY PRINCIPLES

The Provider's security programme is based upon the principles of confidentiality, integrity, availability, accountability and resilience.

Security measures are selected using a risk-based approach which considers the nature of the information processed, the likelihood of potential threats and the impact that a security incident could have upon customers and other stakeholders. Security controls are designed according to the principles of proportionality, defence in depth, least privilege, secure-by-design and continuous improvement.

4. ACCESS MANAGEMENT

Access to production systems is restricted exclusively to authorised personnel whose responsibilities require such access.

Access rights are granted according to the principle of least privilege and are reviewed periodically.

Privileged accounts are subject to enhanced security controls, including strong authentication, logging and monitoring.

User access is removed or modified without undue delay whenever responsibilities change or access is no longer required.

Administrative activities performed within production environments are recorded and monitored where technically appropriate.

5. AUTHENTICATION

The Provider implements authentication mechanisms designed to prevent unauthorised access to the Service.

Authentication requirements are periodically reviewed in light of current security recommendations and emerging threats.

Where appropriate, multi-factor authentication is implemented for privileged administrative access and may also be offered to Customers for user authentication.

Customers remain responsible for managing their own user credentials and for ensuring that Authorised Users maintain appropriate password hygiene.

6. ENCRYPTION

The Provider implements encryption mechanisms appropriate to the nature of the information processed and the associated risks.

Data transmitted across public networks is protected using industry-standard transport encryption protocols.

Where appropriate, Customer Data stored within the production environment is protected using encryption technologies designed to reduce the risk of unauthorised disclosure.

Encryption standards and key management procedures may evolve over time in accordance with recognised industry practices.

7. APPLICATION SECURITY

Security is integrated throughout the software development lifecycle.

Software changes are subject to appropriate design, development, testing and deployment procedures before release into production.

The Provider maintains processes intended to identify, assess and remediate software vulnerabilities within reasonable timeframes.

Security defects are prioritised according to their severity and potential operational impact.

Where appropriate, security testing may include code review, automated analysis, dependency scanning, penetration testing and vulnerability assessments.

8. INFRASTRUCTURE SECURITY

The Service operates within professionally managed cloud environments designed to provide high levels of physical and logical security.

Infrastructure components are continuously monitored for operational health and potential security events.

Security patches are deployed according to the criticality of the identified vulnerabilities and operational requirements.

Network architecture is designed to minimise unnecessary exposure of production systems.

9. LOGGING AND MONITORING

The Provider maintains technical logging appropriate to support operational management, incident investigation and security monitoring.

Security-relevant events may be collected, retained and analysed for the purposes of detecting suspicious activity, protecting the integrity of the Service and complying with legal obligations.

Access to security logs is restricted to authorised personnel.
Logs are protected against unauthorised modification wherever technically feasible.

10. VULNERABILITY MANAGEMENT

The Provider maintains a vulnerability management programme intended to identify and remediate security weaknesses affecting the Service.

Newly identified vulnerabilities are assessed according to their severity, exploitability and potential impact.

Critical vulnerabilities are addressed as a matter of priority.

The Provider may implement temporary mitigation measures where permanent remediation cannot immediately be deployed.

11. INCIDENT RESPONSE

The Provider maintains documented procedures for identifying, analysing, containing, eradicating and recovering from security incidents.

Security incidents are managed by appropriately authorised personnel following documented escalation procedures.
Where a security incident involves Personal Data, the notification procedures established in the applicable Data Processing Agreement shall apply.

Following significant security incidents, the Provider performs an internal review designed to identify root causes and implement appropriate corrective measures.

12. BUSINESS CONTINUITY

The Provider maintains business continuity and disaster recovery arrangements appropriate to the nature of the Service.

Business continuity procedures are periodically reviewed and tested.

Critical operational functions are designed to minimise disruption resulting from significant operational events.

The Provider continually reviews resilience measures in light of technological developments and operational experience.

13. THIRD-PARTY PROVIDERS

The Provider carefully selects third-party suppliers whose services support the operation of the Service.

Suppliers whose services involve access to Customer Data or critical operational functions are subject to appropriate due diligence before engagement.

The Provider periodically reviews the suitability of critical service providers throughout the contractual relationship.

Where third-party providers Process Personal Data on behalf of Customers, they are engaged under appropriate contractual arrangements consistent with applicable Data Protection Law.

14. CUSTOMER RESPONSIBILITIES

Security is a shared responsibility.

The Customer remains responsible for managing its own users, authentication credentials, endpoint security, network connectivity and internal access controls. The Customer shall ensure that only authorised individuals are granted access to the Service and shall promptly disable accounts which are no longer required.

The Customer shall implement appropriate internal procedures to review information generated by the Service before relying upon it for operational, accounting or regulatory purposes.

The Customer shall promptly notify the Provider upon becoming aware of any actual or suspected compromise affecting its user accounts or its use of the Service.

15. CONTINUOUS IMPROVEMENT

Cybersecurity threats continuously evolve.

Accordingly, the Provider reserves the right to modify, strengthen or replace security controls where reasonably necessary to respond to emerging threats, technological

developments, recognised industry practices or changes in applicable legal or regulatory requirements.

Any such modifications shall be implemented in a manner designed to maintain or improve the overall level of protection provided to Customers.

This Information Security Policy forms part of the NEXTOR Contractual Framework and shall be interpreted together with the applicable Agreement.